GOAD — MiniLAB Walkthrough

systemweakness.com/goad-minilab-walkthrough-c4038e70bde7

serkanbenol May 10, 2026

System Weakness is a publication that specialises in publishing upcoming writers in cybersecurity and ethical hacking space. Our security experts write to make the cyber universe more secure, one vulnerability at a time.

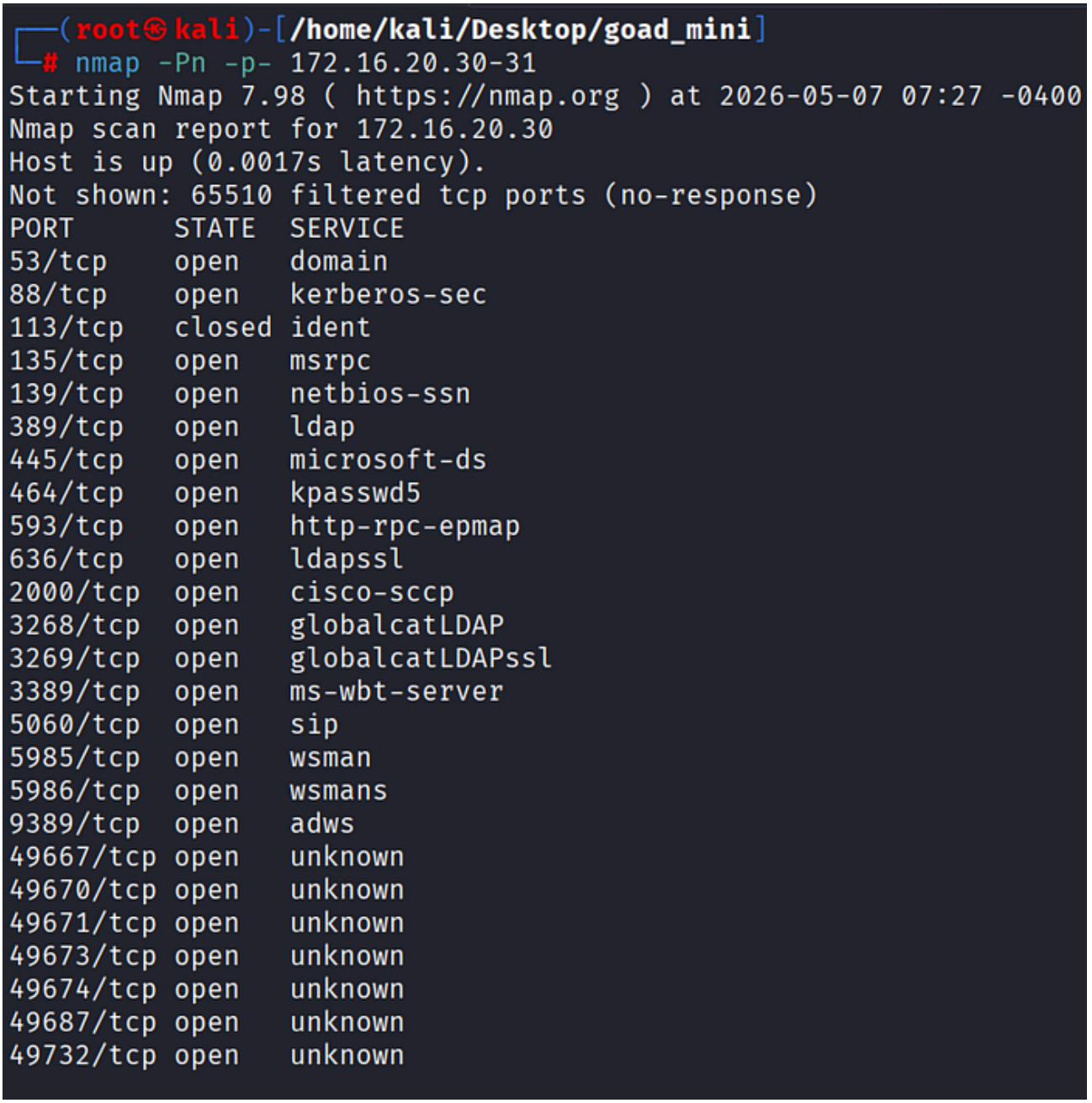
GOAD (Game of Active Directory) is a fantastic lab for practicing AD pentest techniques. In this post, I'll walk through how I fully compromised the MiniLAB environment — including the things that *didn't* work along the way, because that's how pentesting actually goes in real life.

Press enter or click to view image in full size

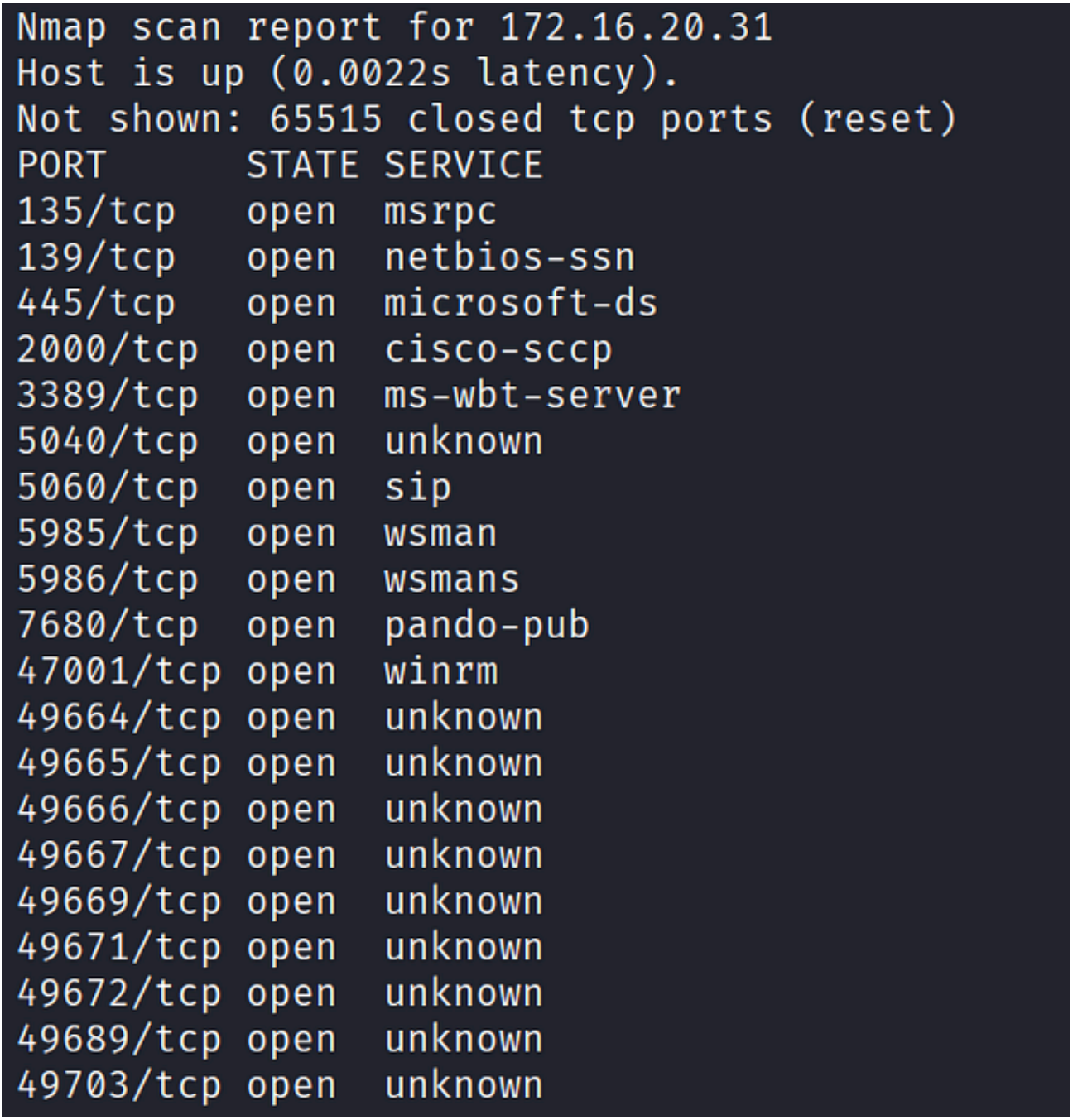
The Garden of earthly delights by Hieronymus Bosch

Our targets : 172.16.20.30–172.16.20.31I start with the very basic nmap scan :

Press enter or click to view image in full size



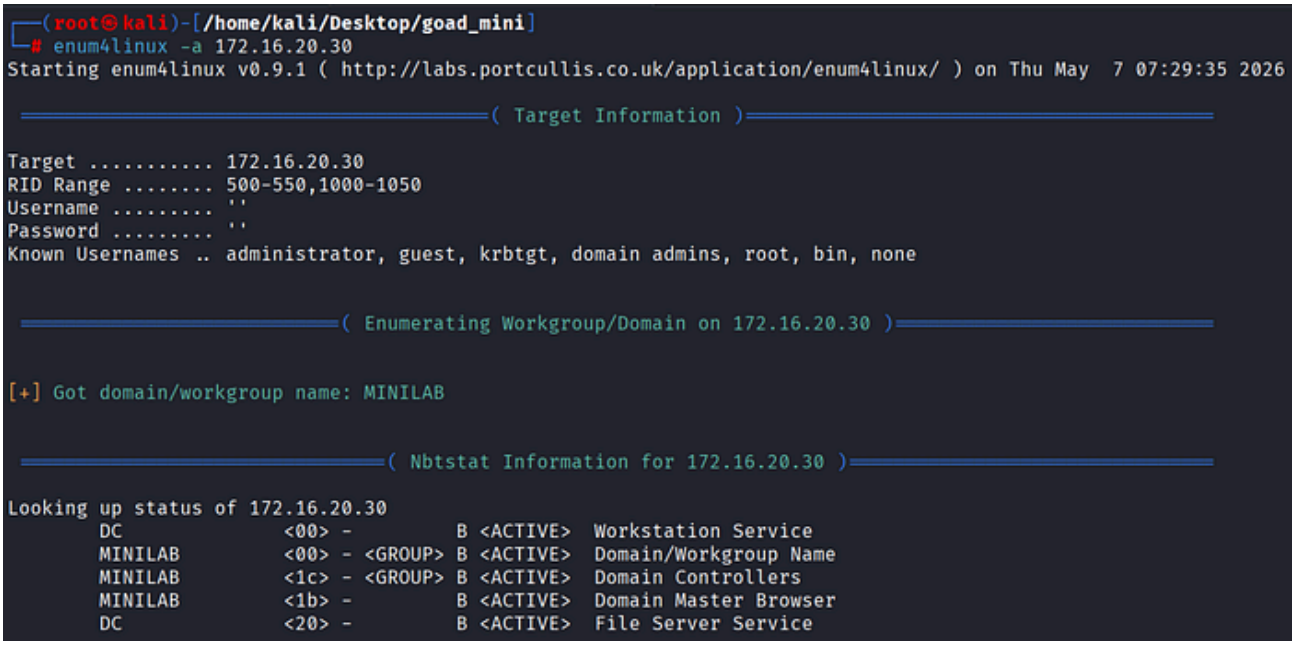
Press enter or click to view image in full size



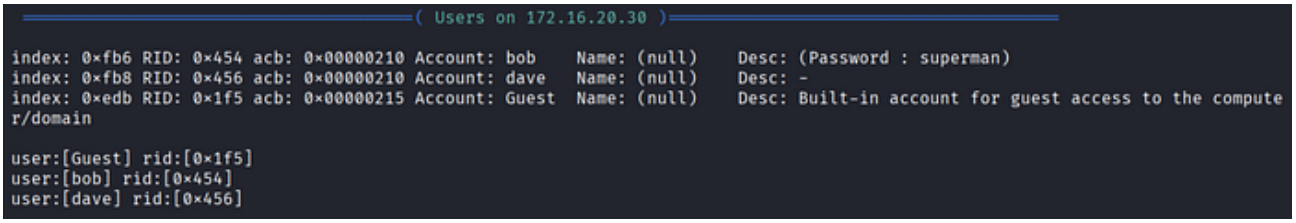
The scan confirmed both hosts as Windows systems. The DC (`172.16.20.30`) exposed the expected Active Directory service stack: **Kerberos (88)**, **LDAP (389/636)**, **SMB (445)**, **DNS (53)**, **RPC (135)**, and **WinRM (5985)**.

After I couple of trial on enumeration, I run`enum4linux-ng` against the DC to test for anonymous/null session access

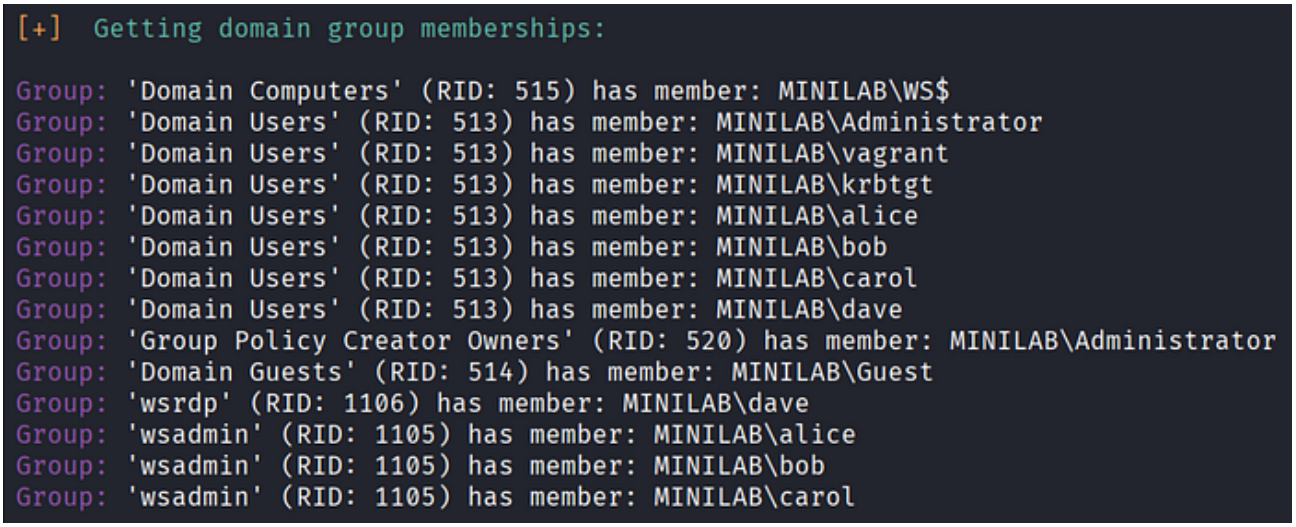
Press enter or click to view image in full size



Press enter or click to view image in full size



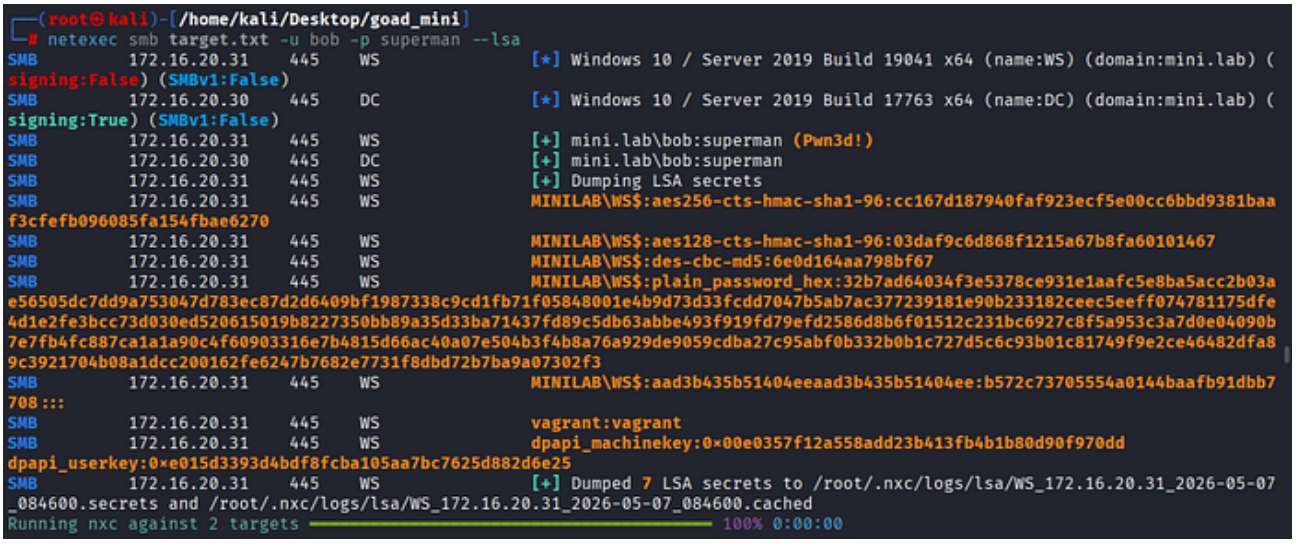
Press enter or click to view image in full size



RID cycling listed the domain users: `Administrator`, `krbtgt`, `vagrant`, `alice`, `bob`, `carol`, `dave`. But the real prize was in the **description** field of the user objects — `bob`'s description had a **cleartext password** left in it.

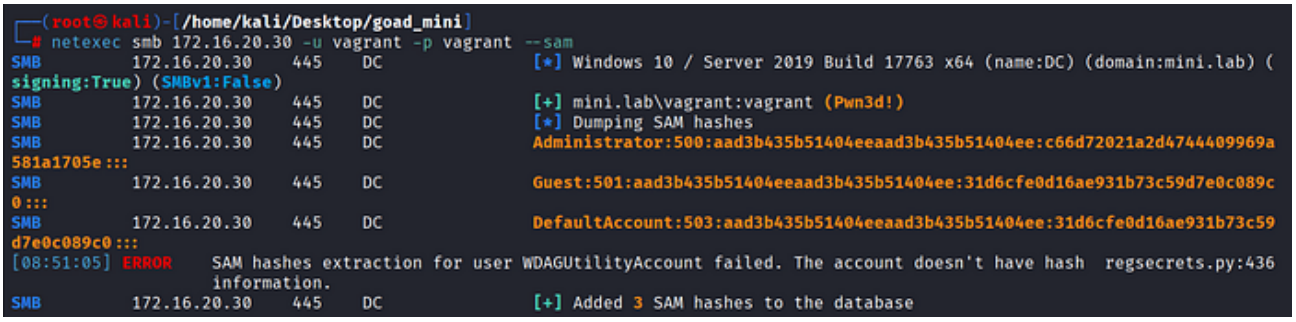
The things I tried but not wasn't very useful :+ asreproasting+ kerberoasting+ pivoting to the host 172.16.20.31 via psexec+ enumerating the shares..The golden shot was extracting the LSA secrets with netexec:

Press enter or click to view image in full size



The output had a goldmine: **`vagrant`**'s cleartext password. Cool!I tried dumping the local hashes on the domain controller:

Press enter or click to view image in full size



Great! We have NT hash of the Administrator which lets us Pass-the-Hash attack :

Press enter or click to view image in full size

I have now shell on DC, which is a full compromise of the domain!

Summary`description field exposure (bob's password)`

↓

```
bob → local admin on 172.16.20.31
↓
LSA Secrets dump → vagrant's cleartext password
↓
vagrant → local admin on the DC
↓
SAM dump → Administrator NT hash
↓
Pass-the-Hash → Domain Admin
```

Thanks for reading!

Sources :https://www.hackingarticles.in/credential-dumping-with-netexec-nxc/
https://juggernaut-sec.com/pass-the-hash-attacks/